RAPPORT D’AUDIT – TP1

Inventaire Active Directory et analyse des chemins d’escalade de privilèges

Réalisé par : Kouya-Bi Gohi Jean-Judicaël

Environnement : Samba Active Directory – meridian.local

Date : 11 novembre 2026

Nature : audit technique en lecture seule

1. Objet et périmètre

Ce rapport présente les résultats du TP1 consacré à l'inventaire d'un annuaire Active Directory/Samba AD et à l'identification d'anomalies susceptibles de favoriser une élévation de privilèges. L'environnement observé utilise le domaine meridian.local et le contrôleur dc01.meridian.local.

Les opérations documentées sont des opérations de consultation : informations du domaine, liste des comptes, export LDAP, comparaison avec le fichier RH, consultation ciblée de comptes et inspection des appartenances aux groupes. Aucune modification de compte, de groupe ou de configuration n'est réalisée dans le cadre de cet audit.

2. Environnement et méthode

Le domaine relevé est meridian.local (NetBIOS : MERIDIAN). Le contrôleur de domaine observé est dc01.meridian.local.

Les captures montrent successivement : les informations du domaine, la liste des utilisateurs Samba, l'extrait d'export LDAP, le fichier hr-roster.csv, les vérifications du compte de Claire Girard et des comptes contractors, l'examen de jcole et svc-erp, puis l'analyse des groupes privilégiés.

L'export LDAP recensait 29 objets de classe utilisateur. La commande samba-tool user list affichait 28 noms ; l'écart s'explique notamment par la présence du compte machine DC01$ dans l'export LDAP. Ces 29 objets ne doivent donc pas être assimilés à 29 salariés.

3. Résultats de l'inventaire et rapprochement RH

Le fichier RH fourni contient 19 lignes nominatives ou contractuelles : 15 salariés et 4 lignes de contrats. Les comptes salariés identifiables dans l'annuaire correspondent globalement aux personnes listées, sous réserve des écarts détaillés ci-dessous.

Pauline Leclerc figure comme nouvelle recrue active dans le fichier RH, mais aucun compte correspondant n'a été retrouvé sous les formes pleclerc, pauline ou leclerc dans la liste consultée. Il s'agit d'un écart RH/annuaire à vérifier (compte éventuellement créé sous un autre identifiant ou provisionnement non terminé).

Claire Girard (cgirard) est placée dans l'OU Plant-Beta et appartient au groupe Engineering, alors que le fichier RH indique un changement vers le département IT en septembre. Il s'agit d'un compte de mobilité dont l'OU et l'appartenance au groupe semblent ne pas avoir été actualisées. La correction éventuelle doit être validée par le responsable RH/IT avant toute modification.

Les comptes contractor1 à contractor4 peuvent correspondre aux quatre contrats actifs du fichier RH, mais les identités exactes ne sont pas établies par les éléments disponibles. Les comptes contractor5 à contractor8 ne trouvent pas de correspondance dans le roster RH actuel : ils sont à classer comme comptes non rapprochés/suspects de devenir obsolètes, et non comme comptes définitivement inactifs sans confirmation du propriétaire des contrats.

Le compte jcole est présent dans l'annuaire, placé dans l'OU Corporate et membre de Finance, mais ne possède aucune ligne correspondante dans le fichier RH fourni. Il constitue un compte non rapproché dont le propriétaire, la fonction et la nécessité doivent être confirmés.

plant-op est un identifiant générique dans Plant-Alpha. Les éléments disponibles ne suffisent pas à confirmer qu'il s'agit d'un compte partagé. Il doit être soumis à une vérification de propriétaire et d'usage.

svc-erp est un compte de service identifié par son SPN HTTP/erp-app.meridian.local et son appartenance à svc-accounts. Il est activé. Les attributs lastLogon et logonCount observés à zéro sur le contrôleur interrogé ne prouvent pas à eux seuls qu'il n'a jamais été utilisé.

4. Analyse des privilèges et des chemins d'escalade

Le constat majeur concerne Finance-ReadOnly. Les membres directs observés de ce groupe sont jmoreau et slaurent. Le groupe Finance-ReadOnly est lui-même membre de Domain Admins. Le chemin d'appartenance constaté est donc : jmoreau → Finance-ReadOnly → Domain Admins et slaurent → Finance-ReadOnly → Domain Admins.

Cette configuration donne aux membres de Finance-ReadOnly des privilèges de Domain Admins par appartenance imbriquée. Le nom Finance-ReadOnly est trompeur au regard des privilèges effectifs. Il s'agit d'un risque critique de sur-privilège et d'escalade de privilèges. Les accès doivent être examinés immédiatement et le groupe ne doit pas être considéré comme un groupe de lecture seule.

Domain Admins contient directement Finance-ReadOnly et Administrator. Enterprise Admins contient Administrator. Administrators contient notamment Enterprise Admins, Administrator et Domain Admins. Ces résultats confirment la propagation des privilèges via les groupes imbriqués.

Le groupe IT-Admins compte lgirard, dbonnet et vchevalier dans les résultats précédemment vérifiés. Aucune preuve ne montre que IT-Admins est membre de Domain Admins ; il ne faut donc pas conclure que ces trois comptes sont administrateurs du domaine.

5. Comptes et indicateurs techniques à examiner

jcole présente userAccountControl = 4260352, soit 4194304 + 65536 + 512. Le compte est activé (512), avec DONT_EXPIRE_PASSWORD (65536) et DONT_REQUIRE_PREAUTH (4194304). L'absence d'exigence de préauthentification Kerberos expose potentiellement le compte à une attaque de type AS-REP Roasting si les conditions d'accès le permettent. Il faut vérifier la justification métier, la robustesse et la rotation du secret, puis supprimer ce paramètre si aucune exception documentée ne le justifie. Aucune exploitation n'a été effectuée ni démontrée.

svc-erp est un compte de service activé avec le SPN HTTP/erp-app.meridian.local. Recommandations : désigner un propriétaire, limiter ses droits au strict nécessaire, contrôler les systèmes qui l'utilisent, mettre en place une rotation de secret adaptée ou un gMSA lorsque l'architecture le permet, et surveiller ses authentifications.

Les comptes contractor1 à contractor8 sont activés (UAC 512) et leur accountExpires est réglé sur 9223372036854775807, valeur indiquant qu'aucune date d'expiration n'est configurée. Pour des comptes contractuels, une date de fin et une revue périodique des accès sont recommandées.

Guest est désactivé (UAC 66082) ; la valeur comprend notamment les indicateurs de compte désactivé, mot de passe non requis et mot de passe n'expirant jamais. Le compte étant désactivé, ces indicateurs ne démontrent pas à eux seuls une possibilité d'accès. krbtgt est également désactivé (UAC 514), état attendu pour ce compte dans le contexte observé.

DC01$ présente UAC 532480, comprenant les indicateurs de compte machine/contrôleur et TRUSTED_FOR_DELEGATION. La délégation sur un contrôleur de domaine doit être examinée selon le rôle et la configuration Samba/AD ; ce seul attribut ne suffit pas à conclure à une vulnérabilité.

6. Synthèse des risques

Critique – Finance-ReadOnly imbriqué dans Domain Admins : jmoreau et slaurent héritent de privilèges Domain Admins malgré le nom du groupe.

Élevé – jcole : compte activé sans préauthentification Kerberos et sans expiration de mot de passe ; propriétaire absent du roster RH.

Élevé – comptes contractors : huit comptes activés sans date d'expiration configurée ; quatre ne sont pas rapprochés du roster actuel et quatre autres nécessitent une confirmation d'identité.

Modéré à élevé – cgirard : incohérence entre le département RH (IT) et l'OU/groupe (Plant-Beta / Engineering).

Modéré – svc-erp : compte de service actif ; gouvernance, propriétaire, droits et rotation du secret à vérifier.

À vérifier – plant-op : identifiant générique dont le caractère partagé et le propriétaire ne sont pas établis.

Écart de provisionnement – Pauline Leclerc : personne active dans le roster sans compte retrouvé sous les identifiants testés.

7. Recommandations et plan d'action

1) Traiter en priorité l'imbrication Finance-ReadOnly → Domain Admins : faire valider le besoin d'administration, retirer les privilèges excessifs après approbation, et créer un groupe réellement limité à la lecture pour les besoins Finance.

2) Identifier le propriétaire de jcole et confirmer son besoin d'accès. Si le compte est légitime, réviser les paramètres Kerberos et la politique d'expiration du mot de passe ; sinon appliquer le processus de désactivation après validation.

3) Réconcilier contractor1 à contractor8 avec les contrats et leurs dates de fin. Définir une date d'expiration, un responsable et une revue périodique pour chaque compte contractuel.

4) Faire confirmer le changement de service de Claire Girard, puis aligner l'OU et les groupes sur le rôle réel selon le processus de gestion des habilitations.

5) Pour svc-erp et plant-op, documenter le propriétaire, la finalité, les systèmes dépendants, les droits et les modalités de rotation des secrets. Éviter les comptes partagés lorsque des comptes nominatifs sont possibles.

6) Vérifier la création du compte de Pauline Leclerc avec l'équipe de provisionnement RH/IT.

7) Mettre en place une revue périodique des groupes privilégiés et des appartenances imbriquées, avec validation à quatre yeux et journalisation.

8. Limites de l'analyse

Les conclusions reposent sur les captures et les résultats de commandes fournis. Le fichier RH constitue la référence de comparaison disponible, mais ne prouve pas à lui seul l'état contractuel réel ni l'existence d'éventuels comptes sous d'autres identifiants.

Les attributs lastLogon et logonCount peuvent être locaux au contrôleur interrogé et ne remplacent pas une analyse consolidée des journaux. Aucune tentative d'exploitation, de connexion avec les comptes, ni modification de l'annuaire n'a été réalisée.

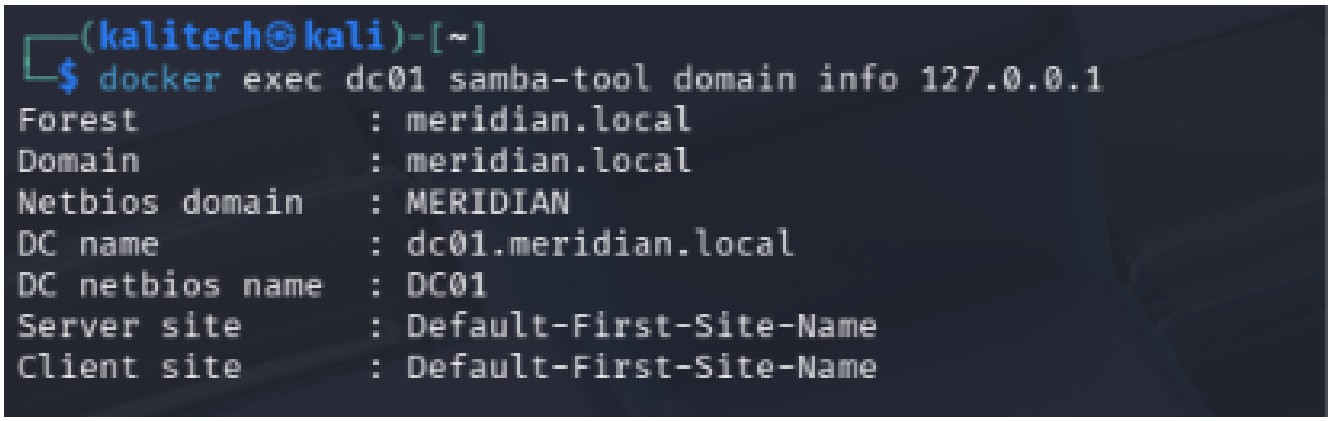
Les captures sont des preuves d'exécution et d'observation ; elles ne remplacent pas une validation par les propriétaires métier des comptes et des habilitations.

9. Conclusion

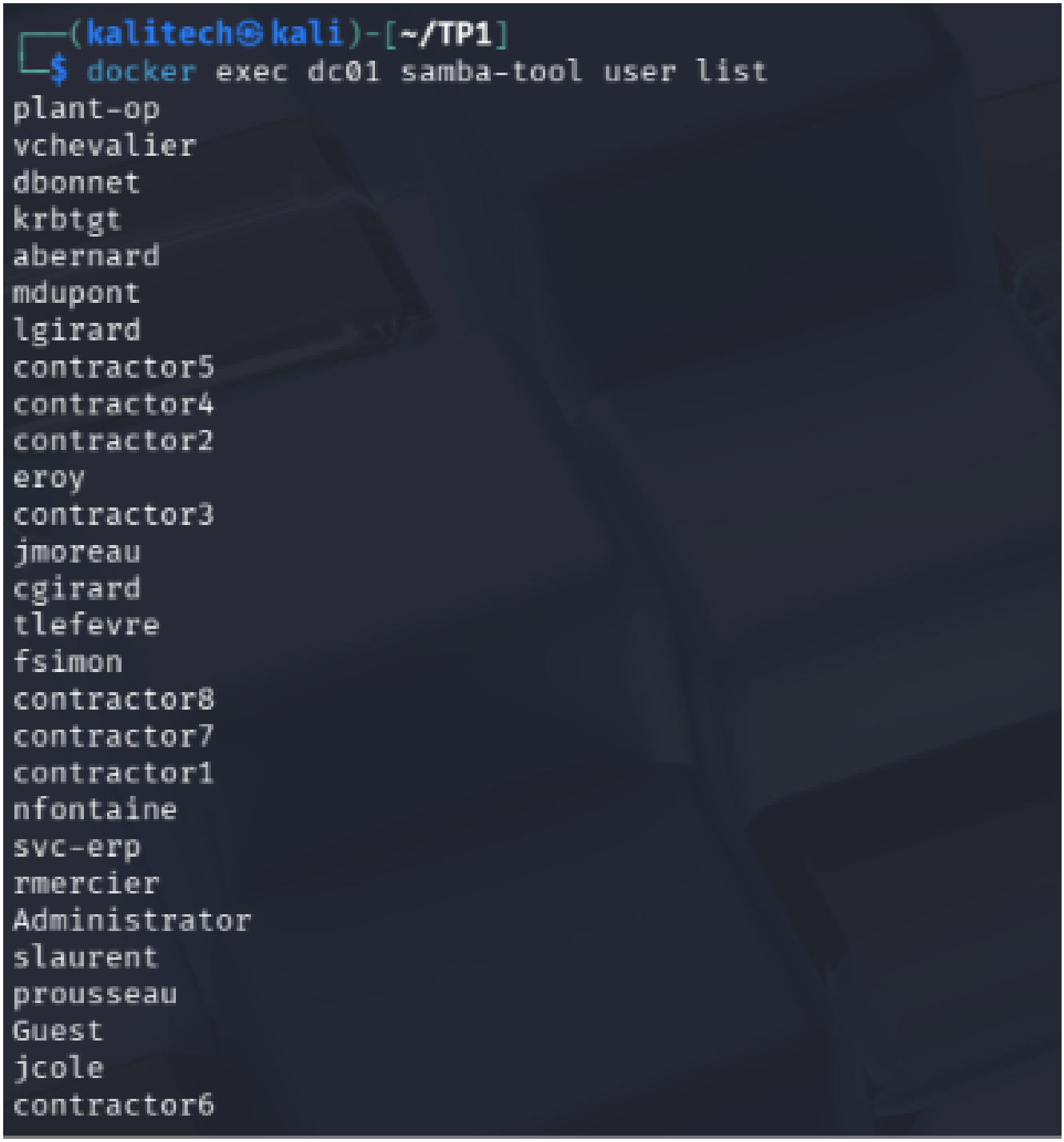
Le TP met en évidence un risque majeur d'héritage de privilèges via Finance-ReadOnly, ainsi que plusieurs écarts de gouvernance des comptes : compte jcole non rapproché et techniquement sensible, comptes contractuels sans expiration, mobilité de Claire Girard non reflétée dans l'annuaire, et compte de service à gouverner. La priorité est de corriger le chemin d'accès privilégié après validation, puis de fiabiliser le rapprochement RH/AD et le cycle de vie des comptes.

10. Annexes – captures des commandes

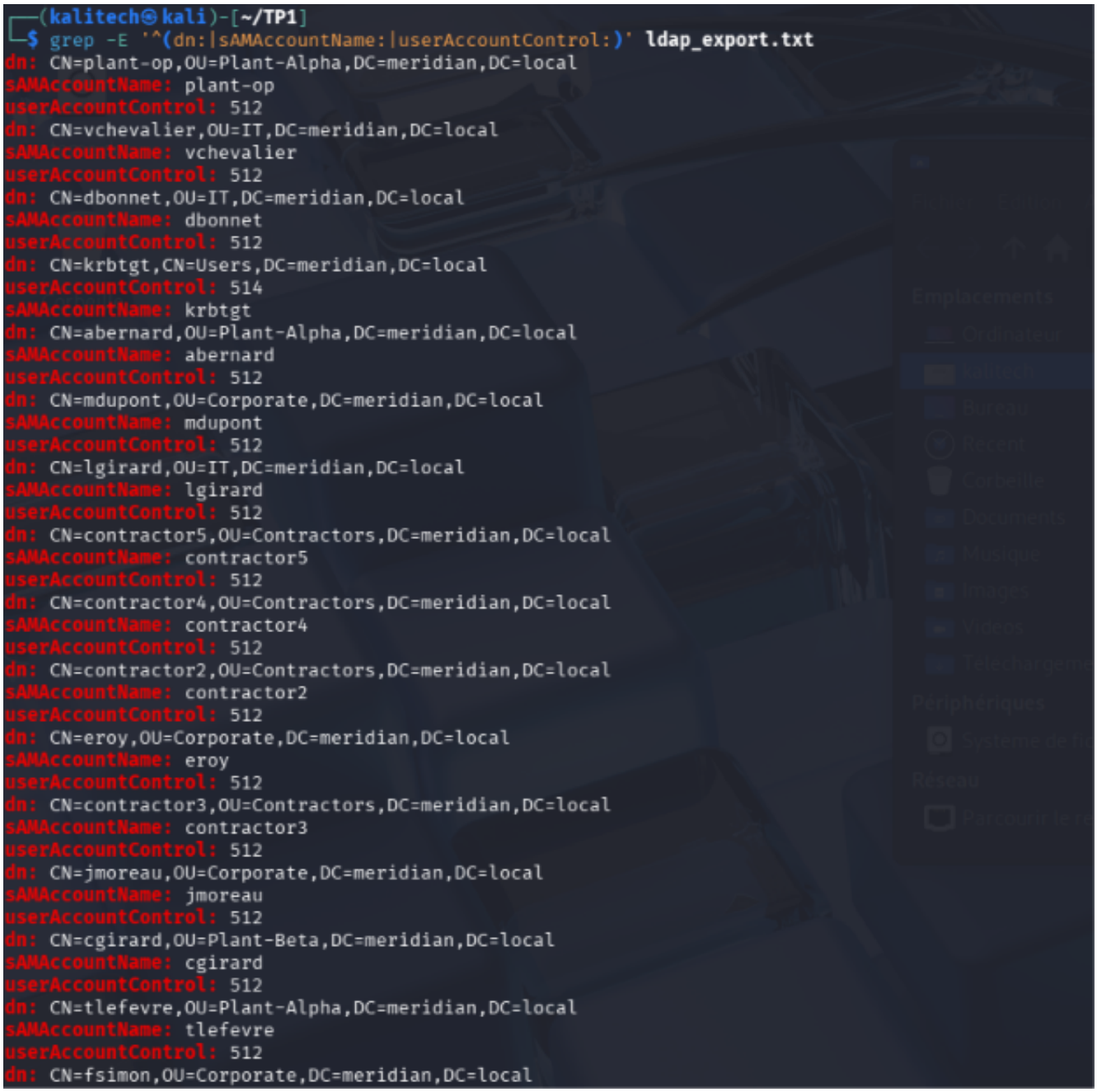
Capture 1 – Informations du domaine et du contrôleur de domaine.



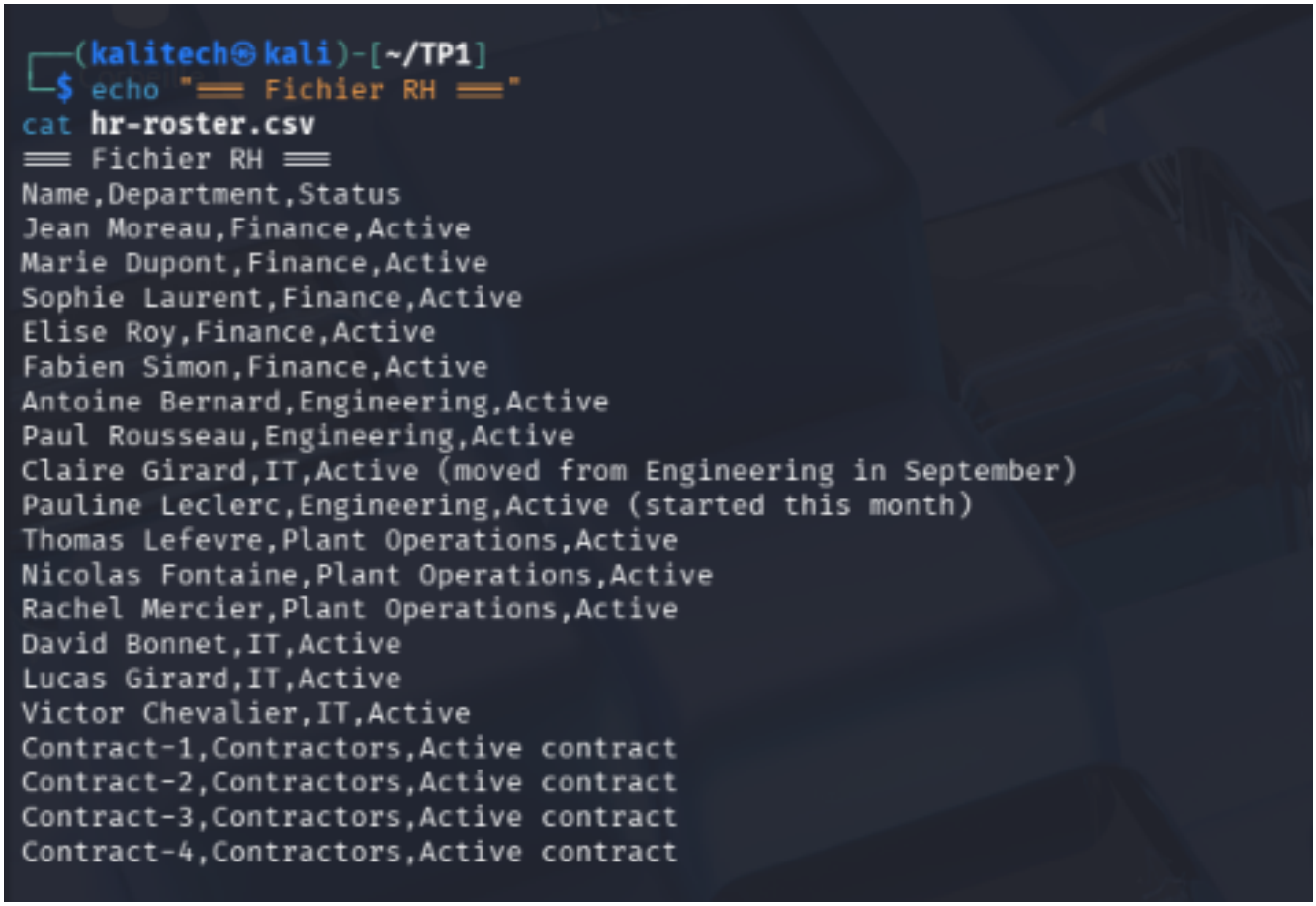
Capture 2 – Liste des comptes retournés par samba-tool user list.



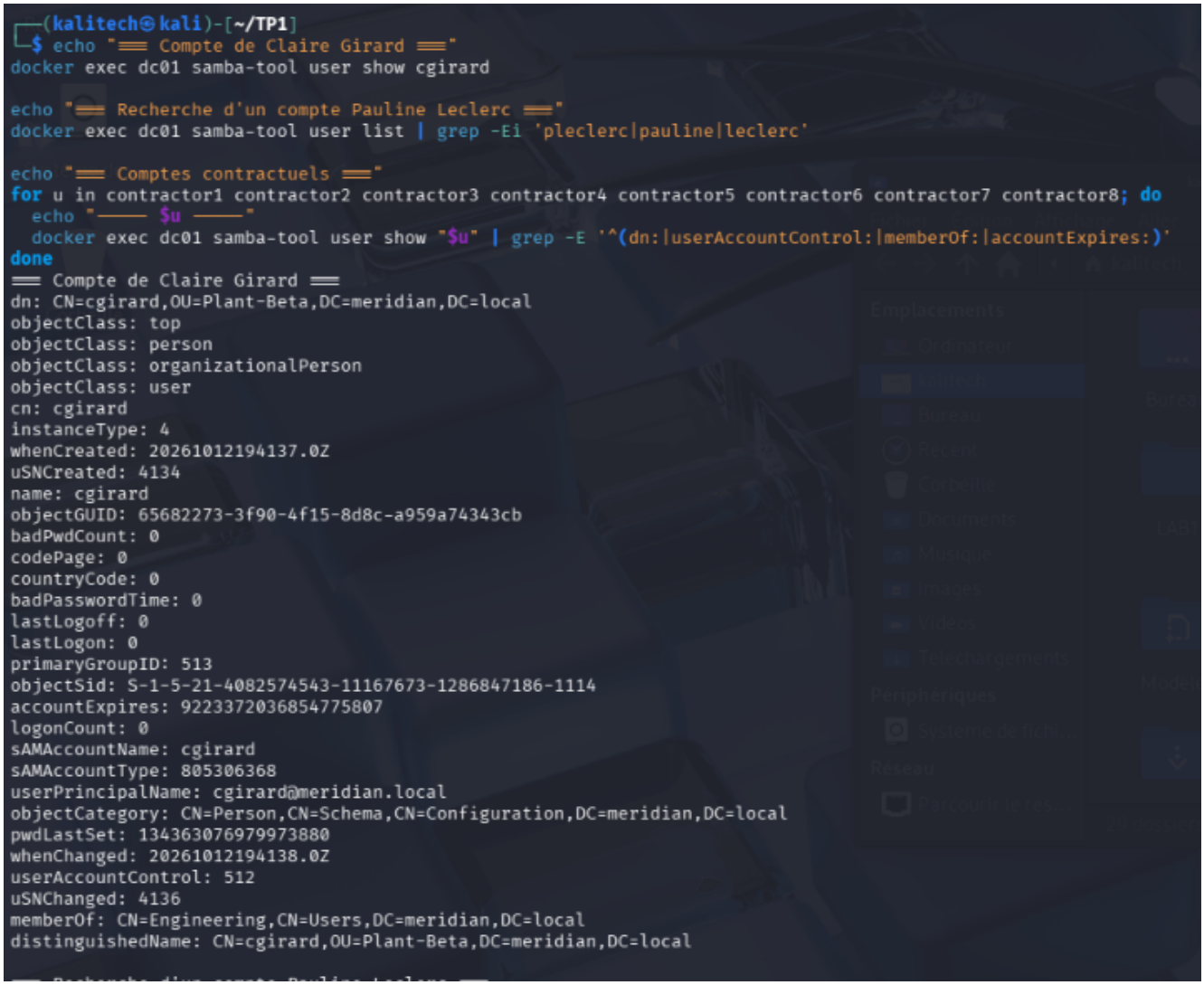
Capture 3 – Extrait de l’export LDAP : DN, identifiants et indicateurs UAC.



Capture 4 – Fichier de référence RH hr-roster.csv.



Captures 5 et 6 – Vérifications de Claire Girard, recherche de Pauline Leclerc et comptes contractuels.

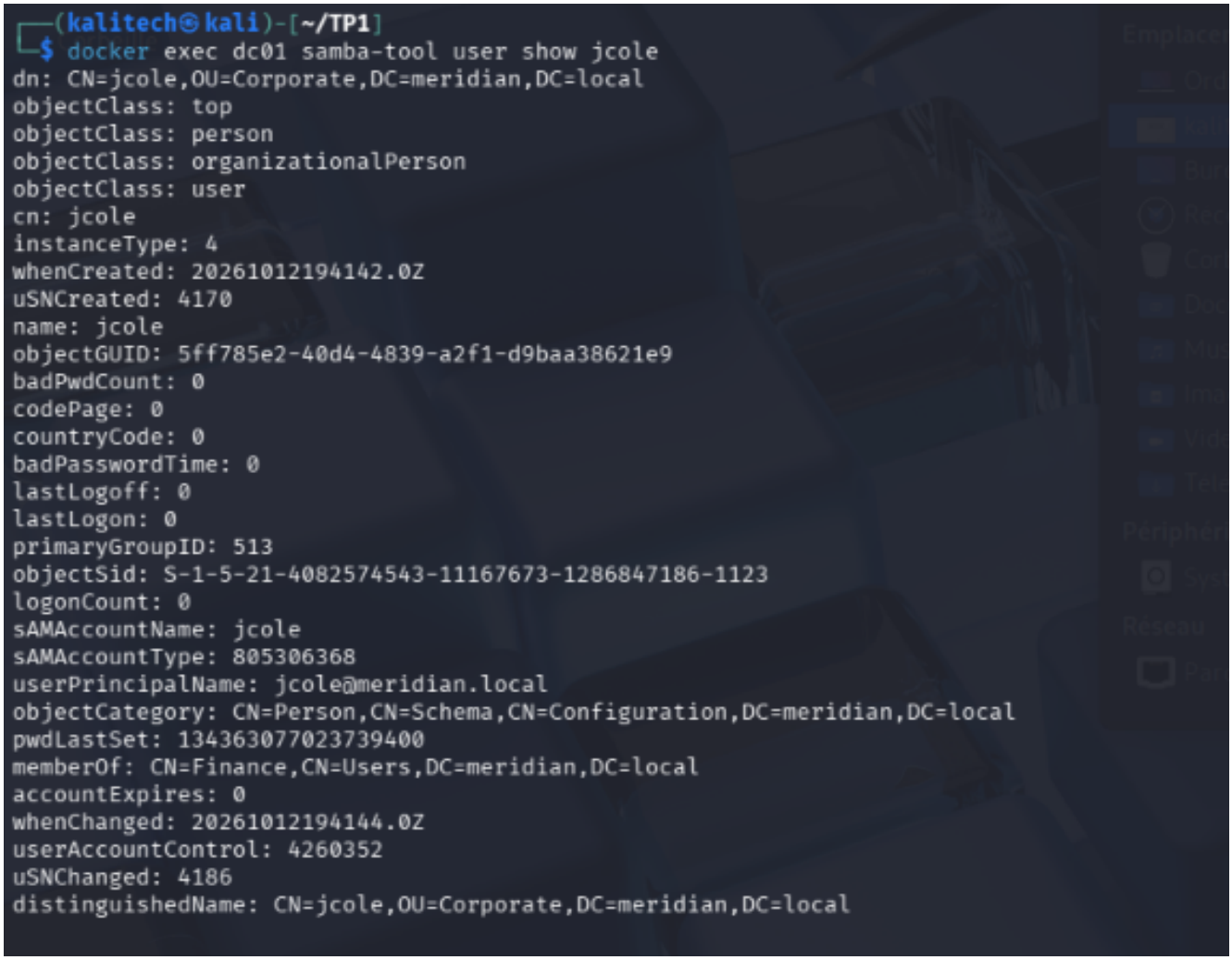


```
┌──(kalitech㉿kali)-[~/TP1]
└─$ echo "== Compte de Claire Girard =="
docker exec dc01 samba-tool user show cgirard

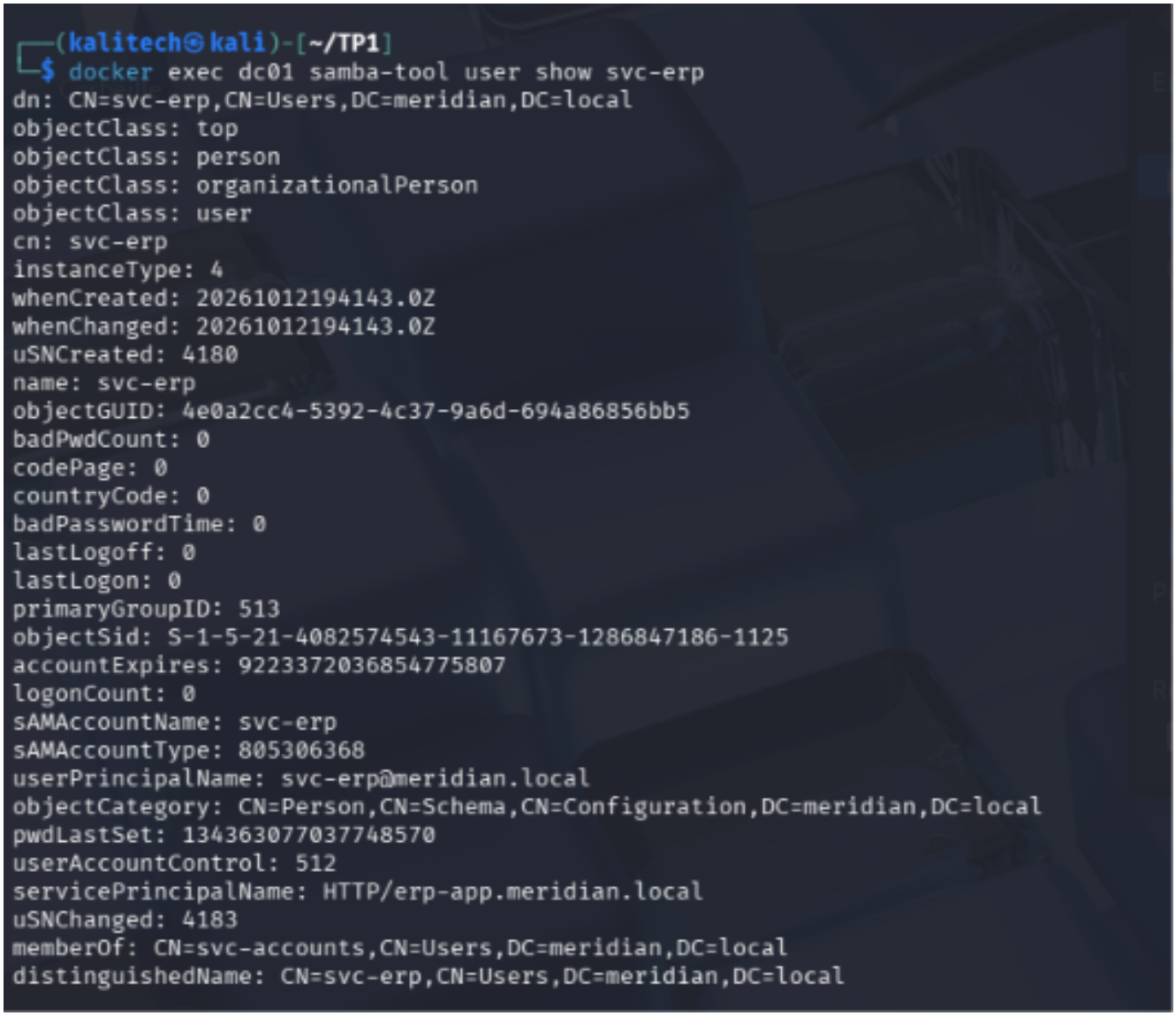
echo "== Recherche d'un compte Pauline Leclerc =="
docker exec dc01 samba-tool user list | grep -Ei 'pleclerc|pauline|leclerc'

echo "== Comptes contractuels =="
for u in contractor1 contractor2 contractor3 contractor4 contractor5 contractor6 contractor7 contractor8; do
  echo "----- $u -----"
  docker exec dc01 samba-tool user show "$u" | grep -E '^(dn:|userAccountControl:|memberOf:|accountExpires:)'
done
== Compte de Claire Girard ==
dn: CN=cgirard,OU=Plant-Beta,DC=meridian,DC=local
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: cgirard
instanceType: 4
whenCreated: 20261012194137.0Z
uSNCreated: 4134
name: cgirard
objectGUID: 65682273-3f90-4f15-8d8c-a959a74343cb
badPwdCount: 0
codePage: 0
countryCode: 0
badPasswordTime: 0
lastLogoff: 0
lastLogon: 0
primaryGroupID: 513
objectSid: S-1-5-21-4082574543-11167673-1286847186-1114
accountExpires: 9223372036854775807
logonCount: 0
sAMAccountName: cgirard
sAMAccountType: 805306368
userPrincipalName: cgirard@meridian.local
objectCategory: CN=Person,CN=Schema,CN=Configuration,DC=meridian,DC=local
pwdLastSet: 134363076979973880
whenChanged: 20261012194138.0Z
userAccountControl: 512
uSNChanged: 4136
memberOf: CN=Engineering,CN=Users,DC=meridian,DC=local
distinguishedName: CN=cgirard,OU=Plant-Beta,DC=meridian,DC=local
```

Capture 7 – Détails du compte jcole et valeur userAccountControl.



Capture 8 – Détails du compte de service svc-erp et SPN HTTP.



Capture 9 – Membres des groupes privilégiés et imbrication Finance-ReadOnly.



```
┌──(kalitech㉿kali)-[~/TP1]
└─$ echo "== Membres de Domain Admins =="
docker exec dc01 samba-tool group listmembers "Domain Admins"

echo "== Membres de Finance-ReadOnly =="
docker exec dc01 samba-tool group listmembers "Finance-ReadOnly"

echo "== Configuration de Finance-ReadOnly =="
docker exec dc01 samba-tool group show "Finance-ReadOnly"

echo "== Membres de Enterprise Admins =="
docker exec dc01 samba-tool group listmembers "Enterprise Admins"

echo "== Membres de Administrators =="
docker exec dc01 samba-tool group listmembers "Administrators"
== Membres de Domain Admins ==
Finance-ReadOnly
Administrator
== Membres de Finance-ReadOnly ==
slaurent
jmoreau
== Configuration de Finance-ReadOnly ==
dn: CN=Finance-ReadOnly,CN=Users,DC=meridian,DC=local
objectClass: top
objectClass: group
cn: Finance-ReadOnly
instanceType: 4
whenCreated: 20261012194134.0Z
uSNCreated: 4109
name: Finance-ReadOnly
objectGUID: ecfc11b2-1a89-48f4-995f-c03705213dff
objectSid: S-1-5-21-4082574543-11167673-1286847186-1104
sAMAccountName: Finance-ReadOnly
sAMAccountType: 268435456
groupType: -2147483646
objectCategory: CN=Group,CN=Schema,CN=Configuration,DC=meridian,DC=local
memberOf: CN=Domain Admins,CN=Users,DC=meridian,DC=local
whenChanged: 20261012194143.0Z
member: CN=jmoreau,OU=Corporate,DC=meridian,DC=local
member: CN=slaurent,OU=Corporate,DC=meridian,DC=local
uSNChanged: 4176
distinguishedName: CN=Finance-ReadOnly,CN=Users,DC=meridian,DC=local

== Membres de Enterprise Admins ==
Administrator
== Membres de Administrators ==
Enterprise Admins
Administrator
Domain Admins
```

Capture 10 – Membres des groupes Enterprise Admins et Administrators.

